

AI-Argus-Harness

Improvements & Smoke-Test Report

Implementation of all 8 recommendations, with verification

Author: Sam Gupta

8 / 8

recommendations

20 / 20

tests passing

16 / 16

CLI checks

0

regressions

Scope

Improve efficiency, reduce false positives and lower hallucination risk, then smoke-test the harness and report the results. Every change preserves the evidence-first, zero-dependency, offline-by-default design.

Status: ALL 8 RECOMMENDATIONS IMPLEMENTED, TESTED & VERIFIED

Version 0.1.0

Author: Sam Gupta

Generated 2026-06-25

Mode: offline / deterministic Target: bundled sample (code + inventory)

AI-Argus-Harness - Improvements & Smoke-Test Report

Page 1

1. Recommendations Implemented

All eight improvement areas below were implemented, tested and verified. Each is summarized with the concrete change.

#1 Content-addressed finding / chain IDs

DONE

finding_id and chain_id are now SHA-derived from stable content (asset + category + title + identity path + primary evidence), enabling diffs, suppressions and idempotent ticket export.

#2 Thread-safe + deterministic evidence

DONE

EvidenceStore and the asset/identity graphs are lock-guarded; evidence refs are content-addressed and de-duplicated, removing the insertion-order race.

#3 Secrets false-positive reduction

DONE

Added Shannon-entropy gating, an anchored placeholder/template denylist, path/extension pruning and per-secret de-duplication.

#4 Category enum + scoring fixes

DONE

Introduced a single-source-of-truth Category enum across all scanners and scoring; removed the dead 'cloud' control-weakness branch and unified the Kubernetes categories.

#5 Decoupled exploitability + gate exemptions

DONE

Exploitability is now category-intrinsic (no severity feedback loop). Credentials score HIGH; an identity path is required only for privilege/access categories.

#6 Parallel ports + os.walk pruning

DONE

Network port probes run concurrently (was up to ~22s/host); the secrets walk prunes skip/noise directories and filters by extension before reading.

#7 LLM grounding + N-sample voting

DONE

Model output is checked for invented entities (CVEs/IPs/ARNs) and judged by N-sample majority voting with a disagreement metric; ungrounded rationales cannot support a finding.

#8 Incremental --diff + suppression store

DONE

A baseline cache yields new/fixed/unchanged diffs across runs; an auditable suppression store accepts known risks by id, dedup-key or title with optional expiry.

2. Smoke-Test Results

The harness was exercised end-to-end in the deterministic offline mode against the bundled sample target (code path + cloud/identity inventory).

- 16 / 16 CLI commands passed: version, stages, plugins, models, doctor, cost, scan, quick, strict, stage-subset, single-scanner, graph, identity, report, evidence, suppressions.
- 20 / 20 unit + regression tests passed (pytest).
- Offline enterprise scan produced 13 findings, 0 review-queue items, 1 attack-path chain, at \$0.00 cost.

- Promoted-finding categories: data-exposure, identity, kubernetes, kubernetes-rbac, saas, secrets, supply-chain.
-

3. Verification Evidence

Determinism & thread-safety (#1, #2)

- finding_ids, chain_ids and evidence refs were byte-identical across repeated runs AND across worker counts (1 vs 8).
- Evidence refs are content-addressed and unique (no duplicates).

False-positive reduction (#3, #4)

- The three real sample secrets are detected while placeholder values ("changeme", "\${ENV_TOKEN}") and test/fixture directories are filtered out.
- A typosquat allowlist suppresses known-legitimate near-name packages.

Severity correctness (#5)

- Hardcoded credentials are now scored HIGH (previously MEDIUM) and are correctly promoted, exempt from the identity-path rule.

Hallucination guard (#7)

- Grounding flags invented entities (e.g. a fabricated CVE / IP not present in the evidence corpus).
- The offline provider short-circuits voting to an evidence-bound verdict with zero disagreement.

Incremental diff & suppressions (#8)

- First --diff run recorded a baseline (+13 new); the immediate re-run reported +0 new / 13 unchanged.
 - Suppressing 'Privileged pod' reduced promoted findings 13 -> 12 with suppressed = 1; the rule is listed by 'argus suppressions'.
-

4. Files Changed

- models.py - Category enum, content_id() helper, compute_id() for Finding/Chain.
 - evidence/store.py - thread-safe, content-addressed, de-duplicating store.
 - graph/asset_graph.py, graph/identity_graph.py - lock-guarded mutations.
 - scanners/secrets.py - entropy/placeholder/path/extension filters, os.walk pruning.
 - scanners/network.py - concurrent port probing.
 - scanners/* - migrated every finding to the Category enum; supply_chain allowlist.
 - scoring/risk_scoring.py - decoupled exploitability; fixed dead/inconsistent branches.
 - reliability/completeness_gate.py - identity-path required only for privilege categories.
 - reliability/adversarial_reviewer.py - grounded N-sample voting integration.
 - reliability/grounding.py, reliability/voting.py - NEW anti-hallucination modules.
 - core/suppressions.py, core/cache.py - NEW suppression store + baseline/diff.
 - core/orchestrator.py - wired IDs, suppressions and --diff; new RunResult fields.
 - config.py, reporting/json_report.py, cli.py - diff flag, suppress commands, output.
 - tests/test_pipeline.py - updated gate tests + 10 new regression tests.
-

5. Notes & Future Work

- A full result cache (skip-recompute) and real provider SDK wiring remain future work; the deterministic offline path stays the default.

- Stealth pacing delays and SARIF location-URI refinement are tracked as follow-ups.
- Reproduce: 'python3 -m pytest' and 'python3 docs/generate_improvements_report.py'.